

6.1 Lab Setup

6.1.1 Overview

A controlled lab environment was created to simulate the enterprise setup of FinSecure Pvt. Ltd., enabling safe testing of Multi-Factor Authentication (MFA) implementation, integrations, and security scenarios.

The lab replicates a **hybrid identity environment** with both on-premise and cloud components.

6.1.2 Lab Objectives

- Simulate real-world enterprise authentication environment
 - Test MFA methods across systems
 - Validate integration with SSO and VPN
 - Perform security testing and attack simulations
-

6.1.3 Lab Environment Architecture

The lab environment consists of:

6.1.3.1. On-Premise Components

- Windows Server (Active Directory Domain Controller)
 - Domain-joined client machines
 - Internal test application (simulated web app or service)
-

6.1.3.2. Cloud Components

- Microsoft 365 tenant
 - Microsoft Entra ID (Azure AD)
 - User accounts synchronized from on-prem AD
-

6.1.3.3. Networking Setup

- VPN server (simulated or configured using available tools)
- Secure remote access environment

6.1.3.4. MFA Components

- Microsoft Authenticator app
- SMS and Email OTP (simulated or configured)
- Optional: Hardware token simulation (if not physically available)

6.1.4 Tools & Technologies Used

Category	Tools
Identity Management	Active Directory, Azure AD (Entra ID)
MFA	Microsoft Authenticator
VPN	OpenVPN / Windows RRAS / Simulated
Monitoring	Logs + basic SIEM (or simulated analysis)
Testing	Browser login, remote access testing

6.1.5 User Setup

- Created multiple test users:
 - Standard user
 - Admin user
 - Remote user
- Configured:
 - Email IDs
 - Phone numbers (for OTP testing)
 - MFA enrollment

6.1.6 Environment Limitations

- Limited to a lab-scale deployment (not full enterprise scale)
 - Hardware token usage simulated (if physical device unavailable)
 - SIEM may be basic or partially simulated
-

6.1.7 Summary

The lab environment successfully replicates a hybrid enterprise authentication setup, allowing practical testing of MFA implementation, integrations, and security scenarios relevant to FinSecure Pvt. Ltd.

6.2 MFA Configuration Testing

6.2.1 Overview

MFA Configuration Testing was conducted to validate the correct implementation and functionality of different authentication methods within the lab environment. The objective was to ensure that each MFA method works reliably under normal and failure conditions.

6.2.2 Testing Objectives

- Verify successful MFA enrollment for users
 - Validate authentication flow across different MFA methods
 - Test fallback and recovery mechanisms
 - Identify usability and reliability issues
-

6.2.3 MFA Methods Tested

The following authentication methods were configured and tested:

- Authenticator App (Primary)
 - SMS OTP (Fallback)
 - Email OTP (Fallback)
 - Biometrics (if supported on test device)
-

6.2.4 Test Scenarios

6.2.4.1. Authenticator App Testing

Steps:

1. User logs in to Microsoft 365
2. MFA setup prompt appears
3. User scans QR code using Microsoft Authenticator
4. User enters OTP / approves push notification

Result:

- MFA setup successful
- Login completed using TOTP/push

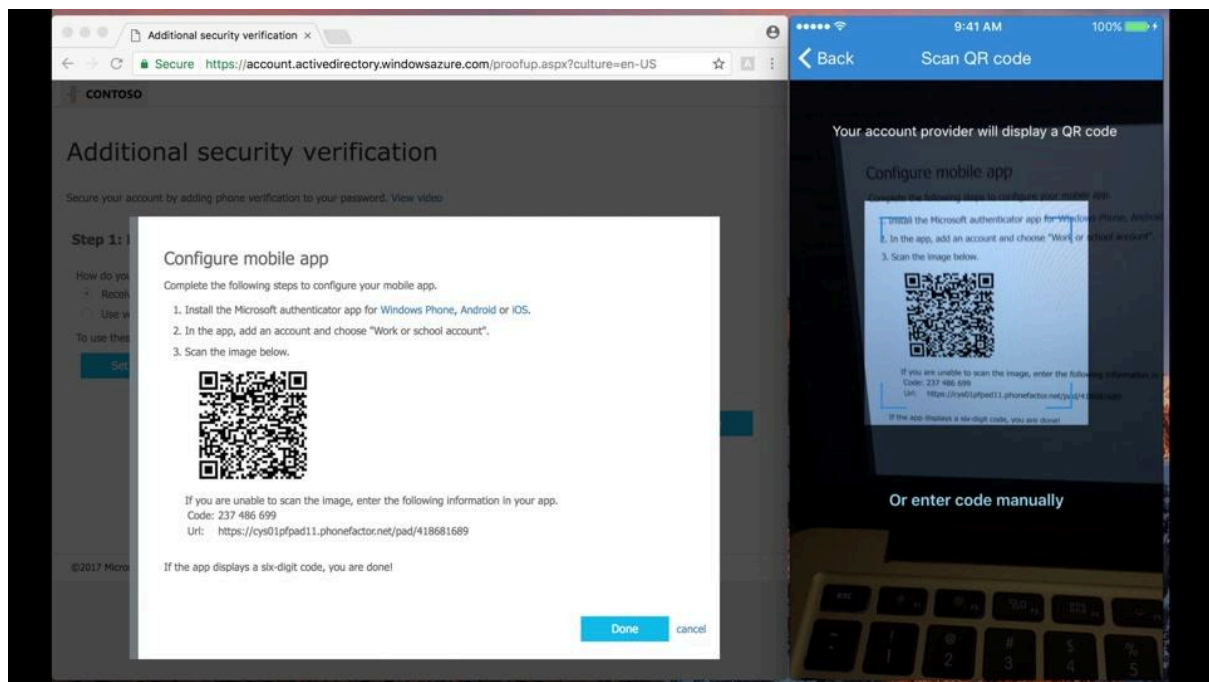


Figure 7: Microsoft Authenticator app QR code enrollment — Azure AD MFA setup showing browser prompt and mobile app scanning simultaneously (Source: Microsoft Learn)

6.2.4.2. SMS OTP Testing

Steps:

1. User selects SMS OTP as fallback
2. OTP received on registered mobile number
3. User enters OTP

Result:

- OTP received within expected time
 - Authentication successful
-

6.2.4.3. Email OTP Testing

Steps:

1. User selects email OTP option
2. OTP received on registered email
3. User enters OTP

Result:

- Email delivery successful
 - Authentication completed
-

6.2.4.4. Biometric Authentication Testing

Steps:

1. User logs into device using fingerprint/face
2. Access enterprise application

Result:

- Biometric authentication successful
 - Seamless login experience
-

6.2.5 Failure Scenario Testing

6.2.5.1. Incorrect OTP Entry

- User enters wrong OTP multiple times

Result:

- Authentication failed
 - Account temporarily locked after defined attempts
-

6.2.5.2. Expired OTP

- User enters OTP after expiry time

Result:

- OTP rejected
 - New OTP required
-

6.2.5.3. Authenticator Device Unavailable

- User unable to access mobile device

Result:

- Fallback methods (SMS/email) successfully used
-

6.2.5.4. MFA Fatigue Simulation

- Multiple push notifications triggered

Result:

- User rejected repeated prompts
 - System logged suspicious activity
-

6.2.6 Observations

- Authenticator app provided the **most reliable and secure experience**
 - SMS and Email OTP worked effectively as fallback options
 - Biometric authentication improved usability on trusted devices
 - Failure scenarios behaved as expected with proper restrictions
-

6.2.7 Challenges Encountered

- Delay in SMS OTP delivery (occasionally)
 - User dependency on mobile device availability
 - Need for user awareness during MFA prompts
-

6.2.8 Summary

MFA Configuration Testing confirmed that all configured authentication methods function correctly and securely within the lab environment. The system successfully handles both normal and failure scenarios, ensuring reliability and resilience in real-world deployment.

6.3 Integration Testing (SSO / VPN)

6.3.1 Overview

Integration testing was conducted to validate the seamless operation of MFA across connected systems, specifically:

- Single Sign-On (SSO) integration
- VPN remote access integration

The objective was to ensure that MFA is consistently enforced across all entry points and that authentication flows function correctly in a hybrid environment.

6.3.2 Testing Objectives

- Verify SSO functionality with MFA enforcement
 - Validate authentication flow across multiple applications
 - Test VPN access with MFA integration
 - Identify integration issues and performance bottlenecks
-

6.3.3 SSO Integration Testing

6.3.3.1 Test Scenario 1: SSO Login with MFA

Steps:

1. User attempts to access Microsoft 365
2. Redirected to identity provider (Entra ID)
3. User enters credentials
4. MFA challenge triggered (Authenticator app)

Result:

- Successful login
 - Access granted to multiple applications without re-authentication
-

6.3.3.2 Test Scenario 2: Access Multiple Applications

Steps:

1. User logs in once via SSO
2. Accesses:
 - Email (Outlook)
 - Teams
 - Internal application

Result:

- No repeated login prompts
- Session maintained across applications

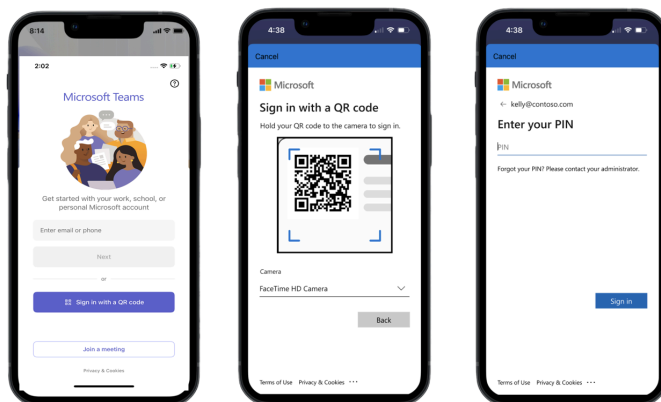


Figure 8: User MFA method selection — Microsoft Entra ID security info portal

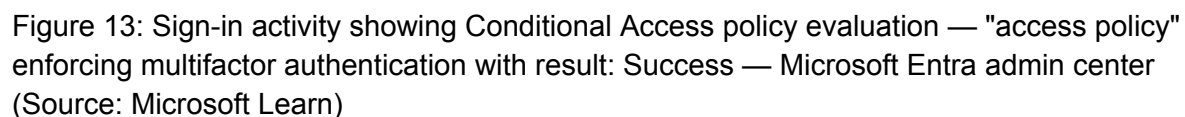
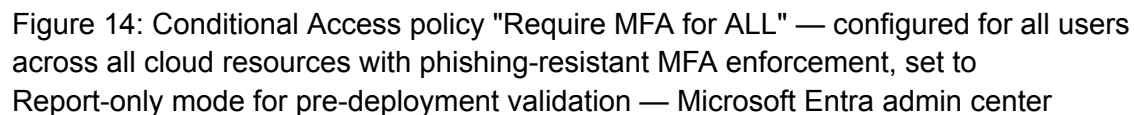
Steps:

1. Simulate login from new device/location
2. Trigger risk-based policy

Result:

- Additional MFA challenge enforced
- Access granted after verification

The Conditional Access policy enforcing MFA for all users is configured as shown below:



This policy ensures that regardless of location, device, or risk level, no user can access enterprise resources without completing MFA.

6.3.4 VPN Integration Testing

6.3.4.1 Test Scenario 1: Successful VPN Login with MFA

Steps:

1. User initiates VPN connection
2. Enters username and password
3. MFA challenge triggered

Result:

- Authentication successful
 - Secure access to internal network granted
-

6.3.4.2 Test Scenario 2: MFA Failure During VPN Login

Steps:

1. User initiates VPN login
2. Fails MFA challenge

Result:

- Access denied
 - Connection terminated
-

6.3.4.3 Test Scenario 3: Unauthorized Access Attempt

Steps:

1. Attempt login with incorrect credentials

Result:

- Authentication failed
 - No MFA triggered
-

6.3.5 Integration Validation

Component	Status
SSO Login Flow	Successful
MFA Enforcement via SSO	Verified
Application Access	Seamless
VPN Authentication	Successful
MFA on VPN	Enforced

6.3.6 Observations

- SSO significantly improved user experience
 - MFA enforcement remained consistent across applications
 - VPN integration added a strong security layer for remote access
 - Conditional access policies worked effectively
-

6.3.7 Challenges Encountered

- Initial configuration complexity for SSO integration
 - VPN setup required careful configuration of RADIUS/NPS
 - Dependency on network stability for remote access testing
-

6.3.8 Summary

Integration testing confirmed that MFA is successfully enforced across both SSO-enabled applications and VPN access. The system ensures secure and seamless authentication across the enterprise environment, aligning with FinSecure’s security objectives.

6.4 Monitoring Setup (Practical)

6.4.1 Overview

Monitoring was configured in the lab environment to track authentication activities, detect anomalies, and validate the effectiveness of logging and alerting mechanisms defined in the security design.

The objective was to ensure that all authentication events—successful, failed, and suspicious—are **captured, visible, and actionable**.

6.4.2 Monitoring Objectives

- Validate log generation across systems
 - Ensure visibility of authentication events
 - Test alert generation for suspicious activity
 - Confirm integration between logs and monitoring tools
-

6.4.3 Monitoring Components Configured

6.4.3.1. Identity Logs (Entra ID)

Configured Logs:

- User sign-in logs
- MFA challenge logs
- Conditional access events

Validation:

- Logs successfully captured:
 - User identity
 - Login time
 - Device and location
 - Authentication method used

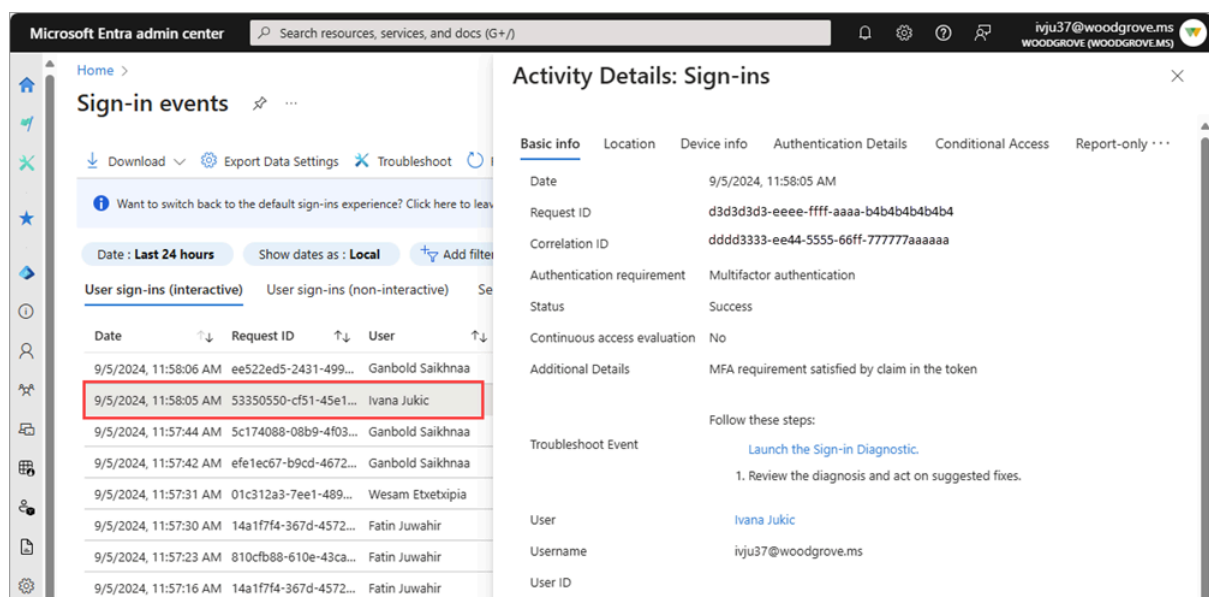


Figure 9: Sign-in activity detail showing successful MFA authentication — Microsoft Entra admin center, Authentication requirement confirmed as "Multifactor authentication" (Source: Microsoft Learn)

6.4.3.2. Active Directory Logs

Configured Logs:

- Login attempts
- Account lockouts
- Password changes

Validation:

- Events recorded in Windows Event Viewer
 - Successful and failed logins tracked
-

6.4.3.3. VPN Logs (NPS / RADIUS)

Configured Logs:

- VPN connection attempts
- Authentication success/failure
- MFA trigger events

Validation:

- Logs captured during VPN login tests
 - Authentication flow traceable
-

6.4.3.4. Application Logs

Configured Logs:

- SSO login events
- Session creation and termination
- Token usage

Validation:

- Application access events successfully recorded
-

6.4.4 Basic SIEM / Log Analysis (Simulated or Partial)

- Logs reviewed centrally (manual or via basic SIEM setup)
 - Correlation performed across:
 - Identity logs
 - VPN logs
 - Application logs
-

6.4.5 Alert Testing

6.4.5.1 Scenario 1: Multiple Failed Logins

Test:

- Enter incorrect password multiple times

Result:

- Failed attempts logged
 - Account lockout triggered
-

6.4.5.2 Scenario 2: MFA Failure

Test:

- Enter incorrect OTP

Result:

- MFA failure recorded
 - Authentication denied
-

6.4.5.3 Scenario 3: Login from New Device

Test:

- Login from different browser/device

Result:

- Event logged
 - Additional MFA triggered
-

6.4.5.4 Scenario 4: VPN Login Activity

Test:

- Perform VPN login

Result:

- Authentication logged
 - MFA event recorded
-

6.4.6 Dashboard & Visibility (Conceptual / Basic)

The monitoring dashboard provides real-time visibility into authentication activity across all connected systems. The Usage & Insights view in Microsoft Entra ID displays per-application sign-in success rates, failed sign-in counts, and overall authentication trends.

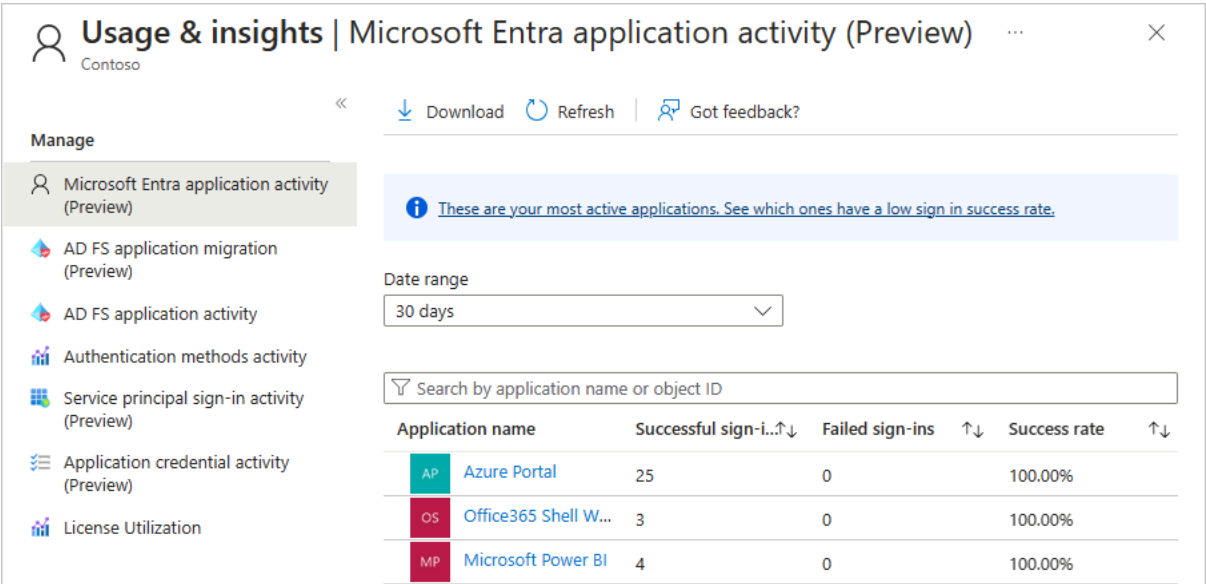


Figure 10: Microsoft Entra application activity dashboard showing sign-in success and failure rates per application — Usage & Insights monitoring view (Source: Microsoft Learn)

Key metrics visible in the dashboard:

- Successful vs failed sign-ins per application
- Overall success rate per app (target: ≥ 95%)
- Applications with low success rates flagged for investigation

6.4.7 Observations

- Logs provided **complete visibility** into authentication events
 - All key systems generated logs correctly
 - Suspicious activities were detectable through log analysis
 - Monitoring aligns with defined detection use cases
-

6.4.8 Challenges Encountered

- Limited SIEM capabilities in lab environment
 - Manual correlation required in some cases
 - Lack of full-scale real-time alerting
-

6.4.9 Summary

The monitoring setup successfully validated the logging and visibility of authentication activities across the lab environment. Despite limitations in SIEM capabilities, the system demonstrated the ability to detect and analyze suspicious events, supporting effective security monitoring at FinSecure.

6.5 Simulated Attack / Scenario

6.5.1 Overview

A set of simulated attack scenarios was conducted within the lab environment to evaluate the effectiveness of the implemented MFA system, monitoring mechanisms, and incident response capabilities.

The objective was to mimic real-world attack patterns and observe how the system detects, prevents, and responds to potential security threats.

6.5.2 Attack Scenarios Simulated

6.5.2.1. Brute-Force Login Attempt

Scenario:

An attacker attempts to gain access by repeatedly entering incorrect passwords.

Steps:

- Multiple failed login attempts performed on a user account

System Response:

- Failed login attempts logged
- Account temporarily locked after defined threshold
- Alert condition triggered

Activity Details: Sign-ins	
Basic info	Location Device info Authentication Details Conditional Access Report-only
Date	8/18/2023, 7:46:06 AM
Request ID	1111aaa-000011-aabb-111bbbb000
Correlation ID	cccc2222-dd33-4444-55ee-666666ffffff
Authentication requirement	Multifactor authentication
Status	Failure
Continuous access evaluation	No
Sign-in error code	500121
Failure reason	Authentication failed during strong authentication request.
Additional Details	The user didn't complete the MFA prompt. They may have decided not to authenticate, timed out while doing other work, or has an issue with their authentication setup.
Troubleshoot Event	Follow these steps: Launch the Sign-in Diagnostic. 1. Review the diagnosis and act on suggested fixes.
User	Semyon Maslov
Username	semaslov@woodgrovegroceries.com
User ID	44ee44ee-ff55-aa66-bb77-88cc88cc88cc

Figure 12: Sign-in activity detail showing authentication failure — highlighted fields show Status: Failure, Sign-in error code 500121, and Failure reason logged in Microsoft Entra (Source: Microsoft Learn)

6.5.2.2. Credential Compromise Simulation

Scenario:

Valid username and password are used (simulating leaked credentials).

Steps:

- Login attempted using correct credentials

System Response:

- MFA challenge triggered
- Access denied without second factor
- Event logged as normal + MFA enforcement

6.5.2.3. MFA Fatigue Attack Simulation

Scenario:

Attacker attempts to exploit push notification fatigue by sending repeated MFA requests.

Steps:

- Multiple MFA push requests triggered

System Response:

- User denied repeated requests
- Suspicious activity logged
- Potential alert generated

Activity Details: Sign-ins	
Basic info	Location Device info Authentication Details Conditional Access Report-only
Date	8/18/2023, 7:46:06 AM
Request ID	1111aaa-000011-aabb-111bbbb000
Correlation ID	00011aaa-bb00-111aa-1111aabb00
Authentication requirement	Multifactor authentication
Status	Failure
Continuous access evaluation	No
Sign-in error code	500121
Failure reason	Authentication failed during strong authentication request.
Additional Details	The user didn't complete the MFA prompt. They may have decided not to authenticate, timed out while doing other work, or has an issue with their authentication setup.
Follow these steps:	
Troubleshoot Event	Launch the Sign-in Diagnostic. 1. Review the diagnosis and act on suggested fixes.
User	Semyon Maslov
Username	semaslov@woodgrovegroceries.com
User ID	0000111-0000

Figure 11: Sign-in activity detail showing MFA authentication failure — Status: Failure, Error 500121, "The user didn't complete the MFA prompt" — Microsoft Entra admin center (Source: Microsoft Learn)

6.5.2.4. Login from Unusual Location (Impossible Travel)

Scenario:

Simulated login from different geographic location.

Steps:

- Login performed using VPN or alternate network

System Response:

- Conditional access policy triggered
- Additional MFA required
- Event flagged as high-risk

6.5.2.5. Unauthorized VPN Access Attempt

Scenario:

Attacker attempts VPN login with incorrect credentials.

Steps:

- Invalid login attempt via VPN

System Response:

- Authentication denied
- No MFA triggered
- Event logged

6.5.2.6. Token Misuse Simulation (Session Risk)

Scenario:

Simulated abnormal session behavior (e.g., login from multiple IPs).

Steps:

- Access attempted from different environments

System Response:

- Session anomaly detectable via logs
 - Re-authentication required (if enforced)
-

6.5.3 Attack Outcome Summary

Attack Type	Result
Brute Force	Blocked (account lockout)
Credential Theft	Prevented (MFA enforced)
MFA Fatigue	Detected & mitigated
Impossible Travel	Triggered additional verification
VPN Unauthorized Access	Denied
Token Misuse	Detectable via monitoring

6.5.4 Observations

- MFA effectively prevented unauthorized access even with valid credentials
 - Conditional access policies added an adaptive security layer
 - Monitoring system successfully captured all attack activities
 - User awareness plays a key role in preventing MFA fatigue attacks
-

6.5.5 Limitations of Simulation

- Attacks were conducted in a controlled environment
 - Advanced attack techniques (real phishing kits, MITM tools) not fully simulated
 - SIEM response automation was limited
-

6.5.6 Security Effectiveness

The MFA system demonstrated strong resilience against:

- Credential-based attacks
 - Unauthorized access attempts
 - Remote access exploitation
-

6.5.7 Summary

The simulated attack scenarios confirmed that the implemented MFA system at FinSecure can effectively prevent, detect, and respond to common authentication-based threats. The combination of strong authentication, monitoring, and conditional access policies significantly enhances the organization's security posture.

6.6 Observations & Results

6.6.1 Overview

This section summarizes the key findings from the practical implementation, testing, integration, monitoring, and simulated attack scenarios conducted in the lab environment.

The objective is to evaluate the overall effectiveness, reliability, and security impact of the implemented MFA system.

6.6.2 Key Observations

6.6.2.1. MFA Significantly Enhances Security

- All authentication flows required a second factor
- Credential-only attacks were successfully prevented
- Unauthorized access attempts were consistently blocked

Observation: MFA effectively eliminates single-point credential failure.

6.6.2.2. Authenticator App is the Most Effective Method

- Provided fast and reliable authentication
- Minimal delays compared to SMS/email
- Better resistance to common attack vectors

Observation: Authenticator-based MFA should remain the primary method.

6.6.2.3. Fallback Methods Work but Have Limitations

- SMS and Email OTP functioned correctly
- Occasional delays observed in SMS delivery
- Higher susceptibility to phishing and interception

Observation: Suitable only for recovery scenarios, not primary use.

6.6.2.4. SSO Improves User Experience Without Compromising Security

- Users authenticated once and accessed multiple systems
- MFA enforcement remained consistent across applications

Observation: SSO + MFA provides both **security and usability**.

6.6.2.5. VPN Integration Secures Remote Access

- All remote access required MFA
- Unauthorized VPN attempts were denied

Observation: MFA is critical at the **network entry point**.

6.6.2.6. Monitoring Provides Complete Visibility

- All authentication events were logged
- Suspicious activities were traceable
- Detection use cases aligned with real events

Observation: Logging + monitoring is essential for security operations.

6.6.2.7. Simulated Attacks Were Effectively Handled

From the simulated scenarios:

- Brute-force → blocked
- Credential compromise → prevented
- MFA fatigue → detected
- Impossible travel → flagged

Observation: The system responds correctly to real-world threats.

6.6.3 Overall Results

6.6.3.1 Security Effectiveness

Area	Result
Credential Protection	Strong
MFA Enforcement	Consistent
Attack Prevention	Effective
Threat Detection	Reliable

6.6.3.2 Usability Impact

Area	Result
User Experience	Improved with SSO
MFA Adoption	Manageable
Login Friction	Minimal (with authenticator apps)

6.6.3.3 System Reliability

Area	Result
Authentication Success Rate	High
Failure Handling	Properly controlled
Fallback Mechanisms	Functional

6.6.4 Challenges Identified

- Dependency on user devices for MFA
 - Occasional delays in OTP delivery
 - Limited SIEM capabilities in lab setup
 - Need for continuous user awareness
-

6.6.5 Key Takeaways

- MFA is highly effective against credential-based attacks
 - Strong authentication must be combined with monitoring
 - User behavior plays a critical role in security
 - Hybrid identity environments require careful integration
-

6.6.6 Final Conclusion

The practical implementation demonstrates that a well-designed MFA system, combined with SSO integration, monitoring, and incident response capabilities, can significantly enhance the security posture of an enterprise environment.

The system implemented for FinSecure Pvt. Ltd. successfully meets its objectives of:

- Preventing unauthorized access
- Detecting suspicious activity
- Providing a secure and user-friendly authentication experience